

Vendor Risk Assessment

Microsoft Azure | Al Rajhi Technologies

Prepared for:	Al Rajhi Technologies
Industry:	Banking and Financial Services
Prepared by:	kayShahbaaz
Date:	27 August 2026
Classification:	CONFIDENTIAL

1. Vendor Overview

Vendor Name:	Microsoft Azure
Service Type:	Cloud Infrastructure (IaaS)
Risk Score:	68 / 100
Risk Level:	High

Microsoft Azure offers a mature security posture, but the IaaS environment will host AI Rajhi's sensitive banking data, creating exposure to cross-border data transfer and shared-responsibility ambiguities. While Azure holds global certifications, specific NCA ECC data-localisation, SAMA incident-reporting, and PDPL contractual obligations are not fully addressed.

2. Risk Red Flags

Potential cross-border data transfers if Azure services are not confined to Saudi data centres	
Ambiguity in the shared-responsibility model for configuration and patch management	2.
Customer-managed encryption keys may be stored outside Saudi Arabia without explicit controls	3.
Multi-tenant side-channel and hypervisor vulnerabilities inherent to public IaaS	4.
Incident-response SLA (typically 24-hours) does not meet SAMA CSF 4-hour notification requirement	5.
Azure's global service catalogue does not guarantee that all IaaS components are confined to Saudi data centres, creating a gap with NCA ECC data-localisation requirements	6.
Contractual language for PDPL compliance (data subject rights handling and breach notification) is not explicitly addressed in Azure's standard terms	7.
Incident-reporting timeframe in Azure's SLA (24-hours) falls short of SAMA CSF's 4-hour mandatory breach notification	8.
No explicit requirement for Saudi-based encryption key storage, leaving a gap with NCA ECC key-management controls	9.

3. Recommended Contract Clauses

Data localisation clause mandating that all production data reside exclusively in Saudi-based Azure regions	
Customer-owned encryption key clause with mandatory Saudi-based key management and escrow provisions	2.
Incident-notification clause requiring notification to AI Rajhi within 4-hours of detection, aligned with SAMA CSF	3.
Audit and inspection rights clause granting AI Rajhi on-site and remote audit access, including SOC 2, ISO 27001, CSA STAR reports	4.
Sub-processor approval clause requiring prior written consent for any third-party services and immediate notification of changes	5.
Termination and data return/destruction clause specifying secure data export, verification, and certified destruction within 30-days	6.

4. Due Diligence Checklist

#	Due Diligence Item	Status
---	--------------------	--------

1	Validate that Azure's Saudi data centres are certified under NCA ECC and host al	Pending
2	Obtain and review Azure's latest compliance attestations (SOC 2 Type II, ISO 270	Pending
3	Review the detailed shared?responsibility matrix for IaaS and confirm AI Rajhi's	Pending
4	Confirm availability of customer?managed keys (CMK) stored in a Saudi?based Key	Pending
5	Test Azure's incident?response workflow and verify SLA commitments meet the 4?ho	Pending
6	Request a current list of Azure sub?processors and assess their compliance with	Pending
7	Conduct a data deletion and sanitisation test to ensure complete removal of data	Pending